



File No.: EXP202312787

RESOLUTION OF SANCTIONING PROCEDURE

From the procedure instructed by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: A.A.A. (hereinafter, the claimant) filed a complaint with the Spanish Agency for Data Protection on July 18, 2023. The complaint is directed against UNIVERSIDADE DE VIGO with NIF Q8650002B (hereinafter, the respondent). The reasons on which the complaint is based are as follows:

The claimant states that he is a professor at the respondent university and that it uses a digital platform called ***PLATAFORMA.1 to inform students about their evaluation and to include reports for those students. He points out that this platform includes the ID number of the professors, which is freely accessible to users of the platform. The claimant believes that this exposure is inappropriate and claims to have requested the anonymization of his ID number from the respondent, without having his request addressed.

Along with the complaint, an image from the platform ***PLATAFORMA.1 is provided, which shows a list of professors, including the claimant, along with their ID numbers.

SECOND: In accordance with Article 65.4 of Organic Law 3/2018, of December 5, on Personal Data Protection and Guarantee of Digital Rights (hereinafter LOPDGDD), this complaint was forwarded to the respondent for analysis and to inform this Agency within one month of the actions taken to comply with the requirements set forth in data protection regulations.

The forwarding, which was carried out in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), was recorded on 10/5/2023 as evidenced by the acknowledgment of receipt in the file.

On 11/6/2023, a response was received by this Agency indicating, among other issues, the following:

"...The professor indicates that "In ***PLATAFORMA.1, in the practical entry, the complete ID numbers of the teaching staff are published... he states that he does not know who has access but that he can see the ID numbers of all the teaching staff in the Department participating in the subject..."

...The response from the vice-rectorate is as follows: "From your email, I thought it was a publication accessible to the public, which is what the law refers to. Within a subject, the teaching staff with whom you share teaching has access to that data. Only you can access it, and neither the students nor the rest of the teaching staff can access this data. As a civil servant, there is a duty of secrecy and confidentiality, so the data we handle as civil servants must be used exclusively for the purpose for which they are intended. I am copying the vice-rectorate of teaching in case they want to contribute or rectify something.

...And the response from the claimant, which concludes the exchange of emails, is: "Thank you for the information. I still find it strange that practically the entire department, in which a good number of people are not civil servants, although it would be understood that they were assimilated, still has access to personal information that is of no interest or contribution, but if the law allows it, there would be nothing to object. For my part, I would prefer that my ID number not be accessible.

...Each professor will see the subjects corresponding to the groups in which they teach and only has access to those subjects or groups for which they are responsible. All personal data of their students to which they have access is necessary and appropriate for educational purposes and is used exclusively for that purpose in accordance with the provisions of Article 5.1 of the GDPR, paragraphs b) and c).

...Students can only access the contents that the teaching staff decides to make visible (teaching materials, tests, grades, work groups, presentation dates, etc.) but in no case to the ID numbers of the teaching staff (as explained in detail in the report of the Director of ATIC) nor to the ID numbers of their classmates.

...Regarding the origin, adequacy, or opportunity to hide the ID number of the teaching staff for the functioning and use of the platform, as stated in the Report of the Director of ATIC, it is not possible to hide, for professors, the ID number of the teachers with whom they share a subject, for two main reasons:

First, because “a basic pillar of ***PLATAFORMA.1 is that the University of Vigo does not modify the source code of ***SISTEMA.2 under any circumstances, in order to apply security patch updates without problems, the possibility of modifying the standard behavior of ***SISTEMA.2 is not contemplated”;

Second: “once the modification of the source code is ruled out, the only realistic option would be to change the configuration of ***SISTEMA.2 to prevent professors from being able to view the ‘username’ of the participants in their courses. However, this option would also imply the loss of academic functionalities (...).

The case of the TFG subject is an exception since, as previously indicated, every professor assigned by their center or faculty to supervise a final degree project is part of this subject.

Automatically, ***PLATAFORMA.1 generates a TFG (or TFM) subject in which the coordinator of each center or faculty is registered as a professor, and it is

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3/18

this who, in accordance with the regulations specific to each center for final degree or master's projects, in each academic year requests or registers the necessary tutoring faculty."

Along with the response document, the following is provided:

- Copy of the emails exchanged between the claimant and the respondent that have been explained in the submitted document.

- Report from the Dean and certificate from the academic secretary regarding the space

***PLATFORM.1 of the TFG subject of the Degree in Translation and Interpreting of the Faculty of Philology and Translation.

- Regulations for the Final Degree Project and academic calendar of the Faculty of Philology and Translation.

- Report on the implementation of the final study project and company internship module of ***SYSTEM.1 from the Vicegerency of Academic Coordination, ensuring in this report the following:

"Once the assignment of the tutor and the student to the project is made, there is a common space that ***SYSTEM.1 refers to as 'student space' in which the student, the tutor, the coordinator, and the secretary interact individually, with no access for the rest of the faculty... the implementation would be in January 2024."

- TECHNICAL REPORT ON ARCHITECTURE AND DESIGN OF ***PLATFORM.1, from the Director of the Information and Communication Technologies Area of the University of Vigo (ATIC), due to the justified absence of the Security Officer.

- DECISION MADE REGARDING THE CLAIM AND REPORT ON CORRECTIVE MEASURES TO PREVENT SIMILAR INCIDENTS, IMPLEMENTATION DATES, AND CONTROLS.

This report details the following:

"1. Regarding the claim with reference number: EXP202312787 submitted by Professor A.A.A. to 'anonymize his ID number', the University of Vigo cannot comply with his request since if the IDs of the faculty are hidden in the ***PLATFORM.1, it would also result in the hiding of the students' IDs, as explained in the reports preceding this one:

Technical report from the Director of ATIC and Report on the causes that led to the incident that originated the claim.

However, the migration of the final degree project subjects to the academic application ***SYSTEM.1 is scheduled for next January. From that moment on, the creation of an individual space for each tutor in those subjects will mean that the ID number, or any other personal data of the faculty in those subjects, will not be visible to any other professor.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

4/18

2. The University of Vigo, regarding the claim with reference number: EXP202312787 has adopted the following corrective measures:

FIRST. - Include a notice reminding all users of the ***PLATFORM.1 of their obligation of confidentiality regarding all personal data contained therein, particularly concerning the teaching staff of the University of Vigo.

Date of adoption: Measure implemented. Below is the homepage of ***PLATFORM.1 where the notice can be seen, available at ***URL.1

Responsible body for its implementation and control: Vice-Rectorate for Planning and Sustainability and Area of Information and Communication Technologies (ATIC).

SECOND. - Approval of a specific Regulation for the use of the ***PLATFORM.1 to provide greater legal security regarding, at least, the following matters: authorized users, mechanisms for reviewing authorizations, purposes and uses of the platform, security and confidentiality measures that must be complied with by the faculty responsible for each of the subjects in ***PLATFORM.1, requirements for registering new users in each subject when done manually by the coordinator of the same.

Expected date for the approval of the regulation: January 2024

Responsible body for its implementation and control: Vice-Rectorate for Planning and Sustainability

THIRD. - Include among the FAQs (frequently asked questions) one with the description of the authorized uses of ***PLATFORM.1 once the corresponding regulation is approved. They will be available to users at the following link. ***URL.2

Expected date of implementation: within 10 days from the approval of the regulation.

Responsible body for its implementation and control: Vice-Rectorate for Planning and Sustainability and ATIC.

FOURTH. - Migrate all TFG and TFM subjects to the teaching Campus of ***SYSTEM.1 creating a specific space for each tutor with their students. Currently, the module for final study projects and external internships is being configured in ***SYSTEM.1, through which the offers for projects and internships will be carried out, within a call made by the center's coordinator.

Expected date of implementation: January 2024. Responsible body for its implementation and control: Management of the University of Vigo."

THIRD: On October 18, 2023, in accordance with Article 65 of the LOPDGDD, the claim submitted by the claimant was admitted for processing.

FOURTH: On October 18, 2024, the Director of the Spanish Agency for Data Protection decided to initiate sanctioning proceedings against the respondent,

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

5/18

for the alleged infringement of Article 25 of the GDPR and Article 5.1.f) of the GDPR, classified under Article 83.4 a) and 83.5 a) of the GDPR, respectively.

FIFTH: Once the aforementioned initiation agreement was notified in accordance with the provisions established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), the party being claimed submitted a written statement of allegations on 25/10/2024 in which it stated, among other things, the following:

"that, regarding the technical aspects related to the inherent difficulties in the design and practical implementation of the platform '***PLATAFORMA.1' (...) (that is, a version of '***SISTEMA.2', which is used in most universities worldwide) and which led to the situation reflected in the file, it is not necessary to elaborate further, as the corresponding reports from the responsible persons have already been submitted to that Agency and are incorporated in the file, so we refer to such reports in all that is deemed appropriate to clarify regarding these aspects, within the framework of the present procedure, reiterating and reaffirming what is indicated in them."

It also refers to the report submitted regarding the complaint, which pointed out the corrective

measures planned in relation to the created situation. Some measures have already been implemented as indicated in the allegations:

"[...] Include a notice reminding all users of the ***PLATAFORMA.1 platform of their obligation of confidentiality regarding all personal data contained therein and, in particular, concerning the teaching staff of the University of Vigo.

"Next, the home screen of ***PLATAFORMA.1 is indicated where the notice can be seen at ***URL.1"

"[...] Approval of a specific Regulation for the use of the ***PLATAFORMA.1 platform in order to provide greater legal security regarding, at least, the following matters: authorized users, mechanisms for reviewing authorizations, purposes and uses of the platform, security and confidentiality measures that must be complied with by the teaching staff responsible for each of the subjects in ***PLATAFORMA.1, requirements for the registration of new users in each subject when carried out manually by the coordinator of the same."

"[...] Include among the FAQ (frequently asked questions) one with the description of the authorized uses of ***PLATAFORMA.1 once the corresponding regulations are approved. They will be available to users at the following link. ***URL.2"

"[...] Migrate all TFG and TFM subjects to the teaching Campus of ***SISTEMA.1, creating a specific space for each tutor with their students. Currently, the module for final study projects and external internships is being configured in ***SISTEMA.1, through which the offers for projects and internships will be carried out, within a call made by the center coordinator.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

6/18

...that the measures provided in the first and third points have already been implemented, as can be easily verified by accessing the hyperlinks indicated above."

"[...] it should be noted, in particular, the implementation of the fourth measure provided, that is, the migration of TFG and TFM subjects to the teaching Campus of ***SISTEMA.1 (the reason why it was understood that the need to approve a specific regulation for the use of the ***PLATAFORMA.1 platform, as the third measure to be implemented, was no longer necessary); since the main problem regarding data protection that motivated the complaint at hand was resolved after this migration took place, as clarified in the report from the Vice-rector for Academic Coordination, which is attached. That UVigo has collaborated from the very beginning with the Agency to reach a satisfactory solution to the reported incident, reacting with the required speed and effectiveness; since our institution rigorously assumes and applies the principles that integrate the data protection policy reflected in the GDPR as well as in the national legislation itself; and that they have been incorporated both in our internal regulations and in our daily way of acting, being widely known and shared by the entire university community."

The report from the Vice-rector for Academic Coordination referenced was attached with the allegations.

SIXTH: On January 27, 2025, a resolution proposal was made, proposing that the Presidency of the Spanish Agency for Data Protection declare that UNIVERSIDADE DE VIGO, with NIF Q8650002B, has infringed the provisions of Article 5.1.f) and Article 25 of the GDPR, classified under Article 83.5 a) and 83.4 a) of the GDPR, and order UNIVERSIDADE DE VIGO, with NIF Q8650002B, to, pursuant to Article 58.2.d) of the GDPR, within two months, demonstrate that it has complied with the necessary measures to adapt the management platform so that the data relating to the ID number of the professors is not accessible to the rest of the users.

After the granted period, it is noted that the party being claimed has not made any allegations.

In view of all that has transpired, the Spanish Agency for Data Protection considers the following proven facts in the present procedure,

PROVEN FACTS

FIRST: It is accredited that in the student management platform (***PLATAFORMA.1) used by the

party being claimed, the ID number of the users is used as an identifier.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

7/18

This fact is derived from the documentation provided by the responding party on 3/11/23 in response to the information request from this Agency, which includes the following report:

- TECHNICAL REPORT ON ARCHITECTURE AND DESIGN OF ***PLATFORM.1, from the Director of the Information and Communications Technologies Area of the University of Vigo (ATIC), due to the justified absence of the Security Officer, in which the following is stated:

“Due to the need to support users without a uvigo email account and the fact that, even with one, each data source system manages user identity differently, the only viable method to maintain synchronized information is through the ID number of each student/teacher. This is why in ***PLATFORM.1, the 'username' of each user is their identity document.”

SECOND: It has been established that users of the student management platform (***PLATFORM.1) managed by the responding party can view the ID numbers of the teachers registered in it.

This is evident from the same report cited in FACT ONE, which states the following:

“Currently, the situation is as follows:

- students cannot see the ID numbers of either teachers or students
- teachers can see the ID numbers of both the students in their subjects and the teachers with whom they share teaching in their subjects
- teachers cannot see the ID numbers of students or teachers with whom they do not share a subject.”

Likewise, the documentation provided in response to the information request from this Agency also includes a report regarding the decision made concerning the complaint, which states the following:

“1. Regarding the complaint with reference: EXP202312787 submitted by Professor A.A.A. to 'anonymize his ID number,' the University of Vigo cannot comply with his request since, if the ID numbers of the teachers are hidden in the platform ***PLATFORM.1, this would also result in the hiding of the students' ID numbers, as explained in the reports preceding this one.”

THIRD: It is evidenced that the responding party, since the implementation of the student management platform (***PLATFORM.1), has not adopted technical and organizational measures to prevent the ID numbers of the teachers from being accessible to other users.

This is derived from the communication made by the responding party regarding the measures implemented, which still do not effectively prevent unauthorized access by third parties to personal data.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

8/18

LEGAL GROUNDS

I

Competence

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on Personal Data Protection and the guarantee of digital rights (hereinafter, LOPDGDD), the Presidency of the Spanish Agency for Data Protection is competent to resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states: “The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, this organic law, the regulatory provisions issued for its development, and, in so far as they do not contradict them, subsidiarily by the general rules on administrative procedures.”

II

Preliminary Issues

In the present case, in accordance with the provisions of Articles 4.1 and 4.2 of the GDPR, there is evidence of the processing of personal data, as the responding party carries out, among other treatments, the collection, registration, and organization of the following personal data of individuals, such as: name and surname and national identity document number.

The responding party carried out this activity in its capacity as the data controller, as it is the one that determines the purposes and means of such activity, by virtue of Article 4.7 of the GDPR.

Article 4, paragraph 12 of the GDPR broadly defines "personal data security breaches" (hereinafter, personal data breach) as "any security breach that results in the accidental or unlawful destruction, loss, alteration of, or unauthorized disclosure of, or access to personal data transmitted, stored, or otherwise processed."

In this case, there is a personal data breach under the circumstances indicated above, categorized as a confidentiality breach, as the ID numbers of various teachers who share a subject or teachers who perform tutoring tasks for TFG and TFM could be viewed through the platform managed by the responding party, exposing, without legitimate justification, their personal data.

III

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
9/18

Allegations to the initiation agreement

First: that, regarding the technical aspects related to the inherent difficulties in the design and practical implementation of the platform "****PLATAFORMA.1" at UVigo (that is, a version of "****SISTEMA.2", which is used in most universities worldwide) that led to the situation reflected in the file, there is no need to elaborate, as the corresponding reports from the responsible individuals have already been submitted to that Agency and are incorporated in the file; therefore, we refer to such reports for any clarifications deemed appropriate regarding these aspects, within the framework of the present procedure, reiterating and affirming what is indicated therein.

In response to this allegation, it should be noted that the respondent party has failed to comply with its obligations derived from Article 5.1 f) of the GDPR by not ensuring the confidentiality and integrity of the personal data of users on the platform ***PLATAFORMA.1, allowing unauthorized access to their ID numbers; therefore, this allegation is dismissed.

Second: that, in the report submitted regarding the complaint, where the corrective measures planned in relation to the created situation are indicated, the following were included:

FIRST. - To include a notice reminding all users of the platform ***PLATAFORMA.1 of their obligation of confidentiality regarding all personal data contained therein, and, in particular, that of the teaching staff of the University of Vigo. Adoption date: Measure implemented. Below is the start screen of ***PLATAFORMA.1 where the notice can be found, which can be viewed at ***URL.1

Responsible body for its implementation and control: Vice-Rectorate for Planning and Sustainability and Area of Information and Communication Technologies (ATIC).

SECOND. - Approval of a specific Regulation for the use of the platform ***PLATAFORMA.1 in order to provide greater legal security regarding, at least, the following matters: authorized users, mechanisms for reviewing authorizations, purposes and uses of the platform, mandatory security and confidentiality measures for the teaching staff responsible for each subject in ***PLATAFORMA.1, requirements for the registration of new users in each subject when done manually by the coordinator of the same. Expected date for the approval of the regulation: January 2024. Responsible body for its implementation and control: Vice-Rectorate for Planning and Sustainability.

THIRD. - To include among the FAQs (frequently asked questions) one with the description of the authorized uses of ***PLATAFORMA.1 once the corresponding regulation is approved. They will be available to users at the following link: ***URL.2

Expected implementation date: within 10 days from the approval of the regulation. Responsible body for its implementation and control: Vice-Rectorate for Planning and Sustainability and ATIC.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

10/18

FOURTH. - Migrate all TFG and TFM subjects to the teaching Campus of ***SISTEMA.1 by creating a specific space for each tutor with their students. Currently, the module for final study projects and external internships is being configured in ***SISTEMA.1, through which the offers for projects and internships will be carried out, within a call made by the center coordinator. Expected implementation date: January 2024. Responsible body for its implementation and control: Management of the University of Vigo.

Third: that the measures provided in the first and third items have already been implemented, as can be easily verified by accessing the hyperlinks indicated above.

Fourth: it is particularly noteworthy the implementation of the fourth measure provided, that is, the migration of TFG and TFM subjects to the teaching Campus of ***SISTEMA.1 (the reason why it was understood that the need to approve a specific regulation for the use of the platform

***PLATAFORMA.1, as a third measure to be implemented, was no longer necessary); given that the main problem related to data protection that motivated the complaint at hand was resolved after this migration took place, as clarified in the report from the Vice-Manager of Academic Coordination, which is attached.

In response to allegations two to four detailing the corrective measures, these do not exempt from the responsibility arising from the breaches identified at the time of the complaint; the appropriate technical and organizational measures to ensure the confidentiality and integrity of users' personal data must be applied before the processing takes place, which is why they are dismissed.

Fifth: that UVigo has collaborated from the very beginning with the Agency to reach a satisfactory solution to the reported incident, reacting with the required speed and effectiveness; given that our institution rigorously assumes and applies the principles that integrate the data protection policy reflected in the GDPR as well as in the national legislation itself; and that these have been incorporated both in our internal regulations and in our daily actions, being widely known and shared by the entire university community.

In response to this allegation, it should be noted that the collaboration referred to does not exempt responsibility for the personal data breach that has occurred among the users of the system used

***PLATAFORMA.1.

IV

Principle of integrity and confidentiality

Article 5.1.f) "Principles relating to processing" of the GDPR states:

"1. Personal data shall be:

(...)

f) processed in a manner that ensures appropriate security of the personal data, including protection against unauthorized or unlawful processing and against

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

11/18

its loss, destruction, or accidental damage, through the application of appropriate technical or organizational measures ("integrity and confidentiality")."

The principle of confidentiality and integrity, as set out in Article 5.1 f) of the GDPR, obliges data controllers to ensure that personal data is processed in a manner that guarantees its confidentiality and integrity, avoiding unauthorized access, misuse, or disclosures to unauthorized third parties. This includes implementing appropriate technical and organizational measures to protect the data against

potential breaches, both external and internal. Such measures must be adequate to prevent risks to the rights and freedoms of individuals from materializing and must be reviewed periodically to ensure their effectiveness.

In the present case, the breach of personal data occurred because the technical and organizational measures necessary to ensure the confidentiality of the ID numbers of all professors sharing a subject or supervisors of TFG and TFM were not adopted, including that of the claimant. It should be noted that the use of the ID number as an identifier on a platform accessible by multiple users significantly increases the risks associated with the confidentiality and integrity of the data, especially when this information is unnecessarily exposed to unauthorized users. The lack of implementation of specific adequate measures would have allowed the breach to occur, thereby violating the principle of confidentiality.

In conclusion, the respondent has failed to comply with its obligations under Article 5.1 f) of the GDPR by not ensuring the confidentiality and integrity of the personal data of the teaching staff on the platform ***PLATAFORMA.1, allowing unauthorized access to their ID numbers. Although corrective measures have been adopted, these do not exempt the responsibility arising from the breaches identified at the time of the claim.

From the proven facts, it is evident that there was a lack of implementation of specific technical measures to prevent users of the platform ***PLATAFORMA.1 from viewing the ID numbers of the teaching staff. Although the migration of subjects to the system ***SISTEMA.1 is detailed, this measure has a future implementation date, so it does not immediately resolve the unauthorized access issue. Furthermore, the confidentiality notice included on the platform is limited to a measure of awareness, without establishing technical restrictions that effectively prevent unauthorized access. In conclusion, the respondent has violated the principle of confidentiality by not timely implementing technical and organizational measures of all kinds, adequate to guarantee the confidentiality and integrity of the personal data of users on the platform ***PLATAFORMA.1, both prior to the claim and subsequently upon becoming aware of it.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

12/18

In accordance with the available evidence, it is considered that the known facts constitute an infringement attributable to the respondent for violating Article 5.1.f) of the GDPR.

V

Classification of the infringement of Article 5.1.f) of the GDPR and qualification for the purposes of prescription

The aforementioned infringement of Article 5.1.f) of the GDPR constitutes the commission of the infringements classified in Article 83.5 of the GDPR, which under the heading "General conditions for the imposition of administrative fines" states:

"Violations of the following provisions shall be subject to administrative fines of up to 20,000,000 EUR or, in the case of an enterprise, an amount equivalent to 4% of the total annual global turnover of the previous financial year, opting for the higher amount:

a) the basic principles for processing, including the conditions for consent under Articles 5, 6, 7, and 9; (...)"

For the purposes of the limitation period, Article 72 "Very serious infringements" of the LOPDGDD indicates:

"1. In accordance with what is established in Article 83.5 of Regulation (EU) 2016/679, the following infringements are considered very serious and shall prescribe after three years:

a) The processing of personal data in violation of the principles and guarantees established in Article 5 of Regulation (EU) 2016/679. (...)"

VI

Declaration of infringement

Article 83 “General conditions for the imposition of administrative fines” of the GDPR in its paragraph 7 states:

“Without prejudice to the corrective powers of the supervisory authorities under Article 58, paragraph 2, each Member State may establish rules on whether and to what extent administrative fines may be imposed on authorities and public bodies established in that Member State.”

Furthermore, Article 77 “Applicable regime for certain categories of controllers or processors” of the LOPDGDD provides as follows:

“1. The regime established in this article shall apply to the processing for which they are responsible or for which they are processors:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

13/18

i) Public Universities.

2. When the responsible parties or those in charge listed in section 1 commit any of the violations referred to in articles 72 to 74 of this organic law, the competent data protection authority shall issue a resolution declaring the violation and establishing, where appropriate, the measures to be adopted to cease the conduct or correct the effects of the violation that has been committed, with the exception of that provided for in article 58.2.i of Regulation (EU) 2016/679 of the European Parliament and of the Council, of April 27, 2016.

The resolution shall be notified to the responsible party or the data processor, to the body to which they hierarchically depend, where applicable, and to the affected individuals who have the status of interested parties, where applicable.

3. Without prejudice to the provisions of the previous section, the data protection authority shall also propose the initiation of disciplinary proceedings when there are sufficient indications for doing so. In this case, the procedure and the sanctions to be applied shall be those established in the legislation on disciplinary or sanctioning regimes that are applicable.

Furthermore, when the violations are attributable to authorities and executives, and the existence of technical reports or recommendations for processing that have not been duly addressed is proven, the resolution imposing the sanction shall include a reprimand naming the responsible official and shall order publication in the Official State Gazette or the corresponding regional gazette.

4. The resolutions related to the measures and actions referred to in the previous sections must be communicated to the data protection authority.

5. The actions taken and the resolutions issued under this article shall be communicated to the Ombudsman or, where applicable, to the analogous institutions of the autonomous communities.”

In accordance with the provisions of this provision and the legal nature of the claimed party, it is appropriate to declare the violation of article 5.1.f of the GDPR.

VII

Data Protection by Design and by Default

Article 25 “Data Protection by Design and by Default” of the GDPR establishes:

“1. Taking into account the state of the art, the cost of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying likelihood and severity that the processing poses to the rights and freedoms of natural persons, the data controller shall implement, both at the time of determining the means of processing and at the time of the processing itself, appropriate technical and organizational measures, such as pseudonymization, designed to apply in a manner...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

14/18

effective the principles of data protection, such as data minimization, and

integrate the necessary safeguards in the processing, in order to comply with the requirements of this Regulation and protect the rights of the data subjects.

2. The data controller shall implement appropriate technical and organizational measures to ensure that, by default, only personal data that is necessary for each specific purpose of the processing is processed. This obligation shall apply to the amount of personal data collected, the extent of its processing, its retention period, and its accessibility. Such measures shall ensure in particular that, by default, personal data is not accessible, without the intervention of the individual, to an indeterminate number of natural persons.

3. An approved certification mechanism under Article 42 may be used as an element that certifies compliance with the obligations set out in paragraphs 1 and 2 of this article.”

This article falls within the general obligations that Chapter IV of the GDPR establishes for the data controller, imposing a design obligation at the time of determining the means of processing, which must effectively ensure compliance with the data protection principles set forth in the general Data Protection regulations.

As indicated in the first finding of fact, it has been established in this case that the users' ID card (DNI) was used as an identifier on the student management platform (**PLATFORM.1), used by the defendant, which, as indicated by the same, was launched as a new virtual campus of the institution in the 2020/2021 academic year, dates on which the GDPR was already in force and there was an obligation to comply with Article 25 of the GDPR, so at the time of designing the system, its obligations regarding data protection should have been taken into account.

The identifier has been linked to the data displayed on the platform (access to the platform is granted with the student and teacher ID cards, which is why the ID cards of teachers and students are shown to teachers who share subjects or are tutors of TFG or TFM).

Consequently, as configured, the platform used has resulted in the commission of an infringement due to the failure to adequately analyze the risks to the rights and freedoms of natural persons, nor to foresee or apply from the design the appropriate technical and organizational measures required by Article 25 of the GDPR.

In this specific case, the failure to foresee these measures from the design allows any teacher to access the ID cards of their colleagues if they share the same subject or are tutors of TFG and TFM. For all the above reasons, it is evident that the defendant has failed to comply with the obligation to design appropriate technical and organizational measures, as they should have adopted another solution that did not share personal data, specifically the ID cards of teachers, which are accessible to other users.

It is considered that the known facts constitute an infringement, attributable to the defendant, for violation of Article 25 of the GDPR.

VIII

Classification of the infringement of Article 25 and qualification for the purposes of prescription

If confirmed, the aforementioned infringement of Article 25 of the GDPR could constitute the commission of the infringements classified in Article 83.4 of the GDPR, which under the heading “General conditions for the imposition of administrative fines” provides:

“Violations of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 10,000,000 EUR or, in the case of an undertaking, an amount equivalent to 2% at most of the total annual global turnover of the previous financial year, opting for the higher amount:

a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43; (...)”

In this regard, the LOPDGDD, in its Article 71 “Infringements” establishes that:

“Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements.”

For the purposes of the limitation period, Article 73 “Infringements considered serious” of the LOPDGDD indicates:

“Based on what is established in Article 83.4 of Regulation (EU) 2016/679, the following are considered serious and shall be subject to a limitation period of two years:

(...)

d) The failure to adopt those technical and organizational measures that are appropriate to effectively apply the principles of data protection by design, as well as the failure to integrate the necessary safeguards in the processing, in the terms required by Article 25 of Regulation (EU) 2016/679. (...)

IX

Declaration of infringement

Article 83 "General conditions for the imposition of administrative fines" of the GDPR in its paragraph 7 establishes:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

16/18

"Without prejudice to the corrective powers of the supervisory authorities under Article 58, paragraph 2, each Member State may establish rules on whether and to what extent administrative fines can be imposed on authorities and public bodies established in that Member State."

Furthermore, Article 77 "Regime applicable to certain categories of controllers or processors" of the LOPDGDD provides as follows:

"1. The regime established in this article shall apply to the processing for which the following are responsible or act as processors:

i) Public Universities.

2. When the controllers or processors listed in paragraph 1 commit any of the infringements referred to in Articles 72 to 74 of this organic law, the competent data protection authority shall issue a resolution declaring the infringement and establishing, where appropriate, the measures that should be taken to cease the conduct or to correct the effects of the infringement that has been committed, except for that provided for in Article 58.2.i of Regulation (EU) 2016/679 of the European Parliament and of the Council, of April 27, 2016.

The resolution shall be notified to the controller or processor, to the body to which it hierarchically depends, where applicable, and to the affected parties who had the status of interested parties, where applicable.

3. Without prejudice to what is established in the previous paragraph, the data protection authority shall also propose the initiation of disciplinary proceedings when there are sufficient indications for it. In this case, the procedure and the sanctions to be applied shall be those established in the legislation on disciplinary or sanctioning regimes that is applicable.

Furthermore, when the infringements are attributable to authorities and executives, and it is proven that there are technical reports or recommendations for processing that have not been duly addressed, the resolution imposing the sanction shall include a reprimand naming the responsible position and shall order the publication in the Official State Gazette or the corresponding regional gazette.

4. The resolutions related to the measures and actions referred to in the previous paragraphs shall be communicated to the data protection authority.

5. The actions carried out and the resolutions issued under this article shall be communicated to the Ombudsman or, where applicable, to the analogous institutions of the autonomous communities."

Therefore, the infringement of Article 25 of the GDPR by the complained party is declared.

X

Sanction

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

17/18

In light of the facts presented, it is considered appropriate to impose a sanction on the complained party for the violation of Articles 25 and 5.1.f) of the GDPR classified in Articles 83.4 and 83.5 respectively of the GDPR. The sanction to be imposed is the declaration of infringement.

Adoption of measures

The controller is required to demonstrate within two months that the management platform has been adjusted so that the data relating to the users' ID number is not accessible to other users, in accordance with what has already been indicated, in accordance with the provisions of the aforementioned Article 58.2 d) of the GDPR, according to which each supervisory authority may "order the controller or processor to ensure that the processing operations comply with the provisions of this Regulation, where appropriate, in a specific manner and within a specified period."

It is warned that failure to comply with the order to adopt measures imposed by this agency in the sanctioning resolution may be considered an administrative infringement in accordance with the provisions of the GDPR, classified as an infringement in its Articles 83.5 and 83.6, which may lead to the initiation of further administrative sanctioning proceedings.

Therefore, in accordance with the applicable legislation and having assessed the criteria for the graduation of the sanctions whose existence has been established, the Presidency of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO DECLARE that UNIVERSIDADE DE VIGO, with NIF Q8650002B, has infringed the provisions of Articles 5.1.f) and 25 of the GDPR, infringements classified in Articles 83.5 a) and 83.4 a) of the GDPR, respectively.

SECOND: TO ORDER UNIVERSIDADE DE VIGO, with NIF Q8650002B, that pursuant to Article 58.2.d) of the GDPR, within two months from the date this resolution becomes final and enforceable, to demonstrate that it has adopted the necessary measures aimed at preventing the visibility of the users' ID/NIF number to other users on the management platform.

THIRD: TO NOTIFY this resolution to UNIVERSIDADE DE VIGO.

FOURTH: TO COMMUNICATE this resolution to the Ombudsman, in accordance with the provisions of Article 77.5 of the LOPDGDD.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure in accordance with Article 48.6 of the LOPDGDD, and in accordance with the provisions of Article 123 of the LPACAP, the interested parties may optionally file an appeal for reconsideration before the Presidency of the Spanish Agency for Data Protection within one month at

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

18/18

counting from the day following the notification of this resolution or directly administrative contentious appeal before the Administrative Litigation Chamber of the National Court, in accordance with the provisions of Article 25 and Section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Administrative Litigation Jurisdiction, within a period of two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law.

Finally, it is noted that in accordance with the provisions of Article 90.3 a) of the LPACAP, the firm resolution in the administrative process may be provisionally suspended if the interested party expresses their intention to file an administrative contentious appeal. If this is the case, the interested party must formally communicate this fact by means of a written document addressed to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency [<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in Article 16.4 of the aforementioned Law 39/2015, of October 1. They must also provide the Agency with documentation that proves the effective filing of the administrative

contentious appeal. If the Agency is not aware of the filing of the administrative contentious appeal within two months from the day following the notification of this resolution, it would consider the provisional suspension terminated.

938-101224

Lorenzo Cotino Hueso

President of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es